

EXERCICE1

Compte rendu Exercice 1 : détection de secrets avec Gitleaks

Objectif de l'exercice

L'objectif de cet exercice était d'utiliser Gitleaks pour analyser un dépôt Git et vérifier s'il contenait des secrets exposés. Dans un contexte DevSecOps, ce type de contrôle est important car un secret poussé dans Git doit être considéré comme compromis, même s'il est supprimé ensuite du fichier concerné. L'historique Git conserve les anciennes versions, ce qui rend l'analyse complète indispensable.

Le dépôt utilisé pour l'exercice est `OWASP/wrongsecrets`, un projet volontairement vulnérable destiné à l'entraînement.

Méthode utilisée

J'ai d'abord cloné le dépôt en conservant tout son historique Git. C'est un point important, car une analyse limitée au dernier état du code ne permettrait pas de retrouver les secrets présents dans d'anciens commits.

```
git clone https://github.com/OWASP/wrongsecrets ./target
```

J'ai ensuite lancé Gitleaks avec Docker Compose, en générant un rapport au format JSON dans le dossier `reports`.

```
docker compose build
docker compose run --rm gitleaks
```

La commande exécutée par le conteneur est la suivante :

```
gitleaks detect --source=/repo --report-format=json --report-
path=/reports/gitleaks-report.json -v
```

Cette commande analyse le dépôt complet, y compris l'historique Git, puis écrit les résultats dans `reports/gitleaks-report.json`.

Résultat obtenu

À la fin du scan, Gitleaks affiche le résumé suivant :

```
4761 commits scanned
scanned ~9441142 bytes (9.44 MB)
leaks found: 1043
```

Le scan a donc détecté 1043 occurrences assimilées à des secrets dans 4761 commits. Ce chiffre est élevé, mais il doit être interprété avec prudence. Une grande partie des résultats provient de règles génériques, qui peuvent détecter des chaînes ressemblant à des clés sans qu'il s'agisse forcément de secrets réellement exploitables.

Le tri par type de secret donne notamment :

```
970  generic-api-key
20   slack-webhook-url
18   private-key
9    slack-bot-token
9    kubernetes-secret-yaml
5    aws-access-token
4    vault-service-token
2    gcp-api-key
2    jwt
1    github-fine-grained-pat
1    hashicorp-tf-api-token
1    gitlab-pat
1    github-pat
```

Les résultats les plus importants à prioriser sont les clés privées, les clés cloud, les tokens Vault et les tokens liés aux plateformes de développement comme GitHub ou GitLab.

Analyse

Le volume de résultats montre que Gitleaks est efficace pour repérer rapidement des éléments sensibles dans un dépôt. Cependant, le nombre brut ne suffit pas à qualifier le risque. Les résultats issus de la règle `generic-api-key` doivent être vérifiés manuellement, car cette règle est volontairement large.

À l'inverse, certains types de secrets sont beaucoup plus critiques. Une clé privée SSH peut permettre un accès direct à un serveur. Une clé AWS ou GCP peut exposer des ressources cloud. Un token Vault peut donner accès à d'autres secrets. Un token GitHub ou GitLab peut compromettre le code source ou une chaîne CI/CD.

Réponses aux questions

Combien de secrets ont été détectés ?

Gitleaks a détecté 1043 occurrences. Ce résultat doit être nuancé, car 970 détections relèvent de la règle générique `generic-api-key`. Les secrets réellement prioritaires sont ceux qui sont typés clairement, comme les clés privées, les tokens cloud, les tokens Vault et les tokens Git.

Quels sont les principaux risques ?

Les risques principaux sont l'accès non autorisé à des serveurs, à des ressources cloud, à du code source ou à des outils de CI/CD. Un secret présent dans Git peut aussi être récupéré longtemps après sa suppression apparente, car il peut rester dans l'historique.

Comment éviter ce problème ?

Il faut éviter de stocker les secrets dans le code et utiliser des variables d'environnement ou un coffre-fort de secrets. Il est également pertinent d'ajouter Gitleaks en hook `pre-commit`, puis dans la CI/CD afin de bloquer automatiquement les commits ou les merge requests contenant des secrets.

Si un vrai secret a déjà été poussé dans Git, la bonne réaction n'est pas seulement de le supprimer du dépôt. Il faut le révoquer, le remplacer, puis vérifier qu'il n'est plus utilisable.